AAA (Authentication, Authorization, Accounting): Three core functions, AAA in Networking & Security, AAA Deployment Models..

1.Create a table comparing Authentication, Authorization, and Accounting (AAA) by listing at least two real-world examples of each function from popular apps like Instagram, Zomato, or Paytm.

ANS:

AAA Function	Meaning	Real-World Example 1	Real-World Example 2
Authentication	Verifies the identity of a user before providing access.	**Instagram:** User enters username/email and password to log in.	**Paytm:** User verifies identity using mobile number, password/OTP, or device authentication.
Authorization	Determines which resources or actions an authenticated user can access.	**Instagram:** A normal user can create posts, while administrative/moderation functions are restricted.	**Zomato:** A restaurant partner can manage its menu and orders, while a customer can only browse restaurants and place orders.
Accounting	Records user activity and resource usage for auditing, monitoring, and security.	**Paytm:** Transaction details such as payment amount, date, receiver, and transaction status are recorded.	**Zomato:** Order history records restaurant, ordered items, amount, payment information, and order status.

Simple Example

Suppose a user opens Zomato.

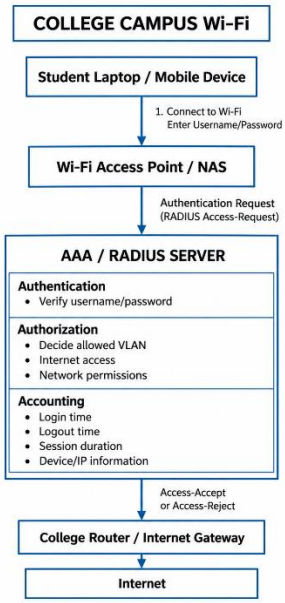
Authentication : The user logs in using a mobile number and OTP.

Authorization : Zomato checks whether the user is a customer, restaurant partner, delivery partner, or administrator and gives access according to that role.

Accounting : Zomato records activities such as login time, order placement, payment, cancellation, and delivery status.

2.Draw a simple network diagram showing how AAA is used to secure access to a WiFi network in a college campus, labeling where authentication, authorization, and accounting take placeHint: Include devices like user laptops, access points, AAA server, and the internet gateway

ANS:



AAA Process

Step 1 – User connects to Wi-Fi

A student opens their laptop or smartphone and connects to the college Wi-Fi network.

Example:

SSID: College-WiFi

Username: student101

Password: ********

Step 2 – Authentication

The Wi-Fi access point sends the student's credentials to the **AAA/RADIUS server**.

The server verifies whether the entered credentials are valid.

If the credentials are correct:

Access-Accept

If the credentials are incorrect:

Access-Reject

This is the **Authentication** process.

Step 3 – Authorization

After successful authentication, the AAA server decides what the student is allowed to access.

For example:

Students → Internet + Student Portal

Faculty → Internet + Faculty Portal + Internal Servers

Network Admin → Full Network Access

This is called **Authorization**.

The server may also assign different VLANs.

Example:

Student VLAN → VLAN 10

Faculty VLAN → VLAN 2

Admin VLAN → VLAN 30

Step 4 – Accounting

When the student uses the Wi-Fi network, the AAA system records information about the session.

For example:

Username: student101

Login Time: 09:15 AM

IP Address: 192.168.10.25

Device MAC Address: AA:BB:CC:11:22:33

Session Duration: 2 Hours

Logout Time: 11:15 AM

These records can be used for:

- Security auditing
- Troubleshooting
- Monitoring network usage
- Detecting suspicious activities
- Investigating security incidents

3.Explain the difference between centralized and distributed AAA deployment models by describing how each would work in a scenario where multiple Flipkart warehouses need secure network access.

ANS:

Consider an example in which **Flipkart operates multiple warehouses**.

Example:

Warehouse 1 – Ahmedabad

Warehouse 2 – Mumbai

Warehouse 3 – Delhi

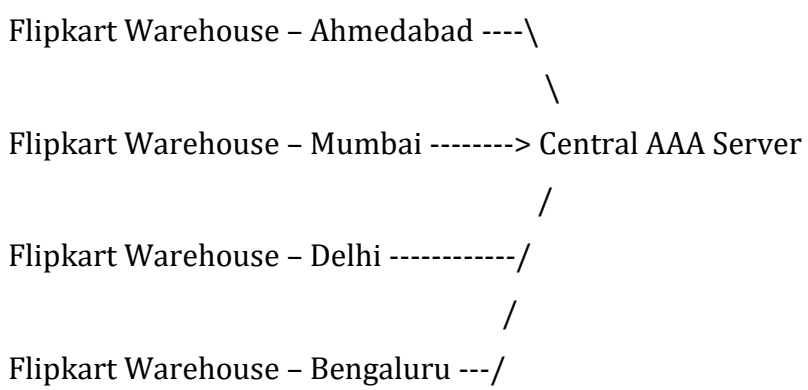
Warehouse 4 – Bengaluru

Each warehouse needs secure network access for employees, managers, scanners, computers, and administrators.

Centralized AAA Model

In a centralized AAA model, all warehouses use a **central AAA server or central AAA**

infrastructure.



The central AAA server controls:

Authentication

Authorization

Accounting

Example

An employee at the Mumbai warehouse tries to access the network.

The warehouse network sends the authentication request to the central AAA server.

The central server checks:

Username

Password

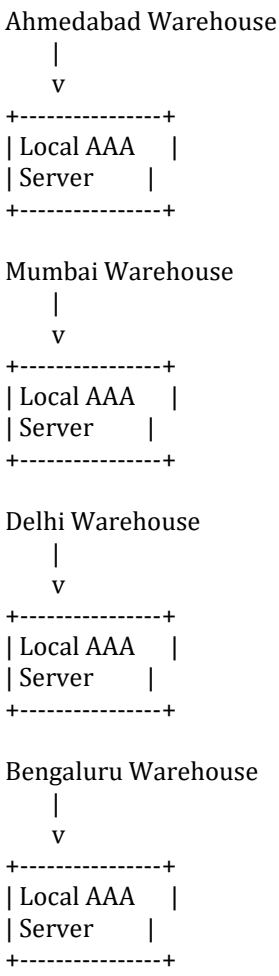
Employee role

Access permissions

If valid, access is granted.

Distributed AAA Model

In a distributed AAA model, multiple locations have their own AAA servers or regional AAA infrastructure.

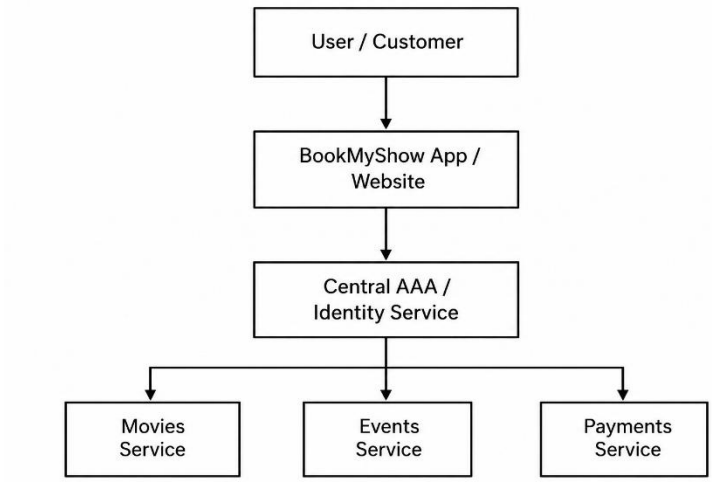


4.Pick any one AAA deployment model and list three advantages and two disadvantages of using it for a large-scale app like BookMyShow.

ANS:

For a large-scale platform such as **BookMyShow**, consider a **Centralized AAA Model**.

A simplified architecture could look like:



The centralized AAA service manages authentication and access policies for users and internal roles.

Advantages

1. Centralized Security Management

Security policies can be managed from one central location.

For example, BookMyShow can control access for:

Customers

Event Organizers

Cinema Partners

Customer Support

Administrators

from a central identity and access management system.

2. Consistent Authorization Policies

All application components can follow the same authorization rules.

For example:

Customer → Book tickets

Cinema Partner → Manage cinema information

Event Organizer → Manage their events

Admin → Administrative functions

This reduces inconsistent access controls.

3. Easier Monitoring and Auditing

Authentication and security logs can be collected centrally.

Examples of information that can be recorded:

Login attempts

Password changes

Ticket bookings

Refund requests

Administrative changes

Suspicious login attempts

Security teams can analyze these records more easily.

Disadvantages

1. Central Service Dependency

If the central AAA infrastructure becomes unavailable and there is no redundancy, authentication and authorization functions may be affected.

For example:

AAA Service Failure

↓

Login Requests May Fail

↓

Users May Be Unable to Access Services

2. High Infrastructure Requirements

A large application like BookMyShow can have very high traffic during popular movie releases or major events.

Therefore, the AAA infrastructure may require:

- Load Balancers
- Multiple Authentication Servers
- Database Replication
- Caching
- Failover Servers
- Monitoring Systems

This increases infrastructure and management complexity.

5.Use ChatGPT or another AI tool to generate a sample AAA policy for a Zomato-like app, specifying what actions are authenticated, which roles are authorized for each action, and what accounting logs should be kept. Paste the generated policy and highlight one thing you would change to make it more secure.

ANS:

Sample AAA Security Policy

1. Purpose

The purpose of this AAA policy is to ensure that only authenticated users can access the application and that users can perform only those actions permitted by their assigned role.

The system will implement:

- Authentication
- Authorization
- Accounting

A. Authentication Policy

Users must authenticate before performing sensitive actions.

Customer Authentication

Customers should authenticate before performing actions such as:

Placing an order

Making a payment

Viewing saved addresses

Viewing order history

Cancelling an order

Updating profile information

Authentication methods may include:

Mobile number + OTP

Email + password

Trusted identity provider login

Device authentication

Restaurant Partner Authentication

Restaurant partners must authenticate before accessing the restaurant management dashboard.

Authentication should be required for:

Adding menu items

Changing food prices

Accepting orders

Rejecting orders

Updating restaurant information

Viewing revenue information

Delivery Partner Authentication

Delivery partners must authenticate before accessing delivery-related features.

Example:

Login using registered mobile number + OTP

They may be required to authenticate before:

Accepting delivery assignments

Viewing customer delivery details

Updating delivery status

Administrator Authentication

Administrators should use stronger authentication.

Example:

Username/Email

+

Password

+

Multi-Factor Authentication

Examples of MFA:

Authenticator App

Security Key

OTP

B. Authorization Policy

The application should use **Role-Based Access Control (RBAC)**.

Possible roles:

Customer

Restaurant Partner

Delivery Partner

Customer Support

Administrator

Authorization Table

Action	**Customer**	**Restaurant Partner**	**Delivery Partner**	**Support Staff**	**Administrator**
Browse Restaurants	Yes	Yes	Yes	Yes	Yes
Place Food Order	Yes	No	No	No	No
Make Payment	Yes	No	No	No	No
View Own Orders	Yes	Restaurant Orders Only	Assigned Deliveries Only	Support Cases	Yes

Update Restaurant Menu	No	Yes – Own Restaurant	No	No	Yes
Accept Restaurant Order	No	Yes	No	No	Yes
Accept Delivery	No	No	Yes	No	Yes
Update Delivery Status	No	No	Yes	Limited	Yes
Process Customer Support Request	No	No	No	Yes	Yes
Manage Users	No	No	No	No	Yes
Change Security Settings	No	No	No	No	Yes

The system should follow the **Principle of Least Privilege**.

This means:

A user should receive only the minimum permissions necessary to perform their role.

C. Accounting Policy

The application should maintain security and activity logs.

Authentication Logs

Record:

- User ID
- Login date
- Login time
- IP address
- Device information
- Login success/failure
- Authentication method
- Logout time

Example:

- User ID: CUST1023

Login Time: 10:25 AM

IP Address: 192.168.1.20

Device: Android

Status: Successful Login

Order Logs

Record:

Order ID

Customer ID

Restaurant ID

Order date

Order time

Ordered items

Order amount

Order status

Example:

Order ID: ORD501

Customer: CUST1023

Restaurant: REST205

Amount: ₹650

Status: Delivered

Payment Logs

Record:

Transaction ID

Order ID

Payment method

Transaction time

Transaction status

Refund status

Sensitive payment credentials should **not** be stored directly in ordinary application logs.

Restaurant Activity Logs

Record activities such as:

- Menu updates
- Price changes
- Order acceptance
- Order rejection
- Restaurant status changes

Example:

- Restaurant ID: REST205
- Action: Menu Price Changed
- Item: Paneer Pizza
- Old Price: ₹250
- New Price: ₹280
- Time: 11:45 AM

Delivery Partner Logs

Record:

- Delivery assignment
- Order acceptance
- Pickup confirmation
- Delivery status
- Delivery completion time

Administrator Logs

Administrator activities should be logged carefully.

Record:

- Administrator ID
- Login time
- User management changes
- Restaurant account changes
- Role/permission changes

Security configuration changes

Account suspension

Example:

Admin ID: ADMIN05

Action: Restaurant Account Suspended

Restaurant ID: REST405

Time: 03:15 PM

These logs are important because administrator accounts contain powerful permissions.

One Security Improvement I Would Make

The original policy allows multiple authentication options, but I would make **Multi-Factor Authentication mandatory for all privileged accounts**, especially:

Administrators

Restaurant administrators

Customer support staff with sensitive access

Instead of allowing:

Password Only
the system should require:
Password
+
Authenticator App / Security Key
For example:
Admin enters username/password
↓
Password is verified
↓
MFA challenge appears
↓
Admin verifies authenticator/security key
↓

Access Granted